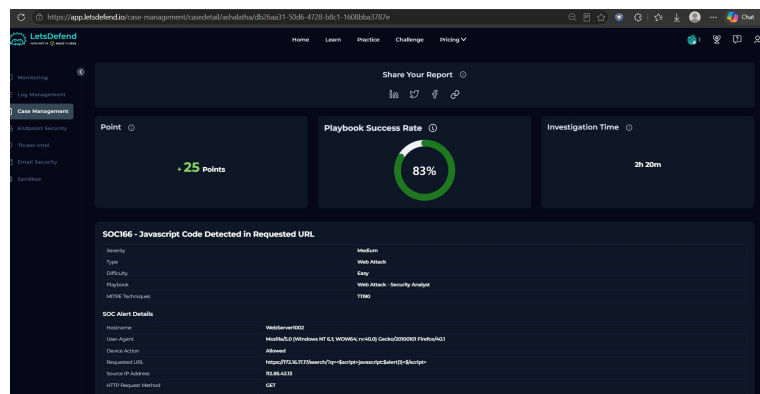


SOC166 - JavaScript/XSS Web Attack Investigation

SOC log analysis of a JavaScript Code Detected in Requested URL alert, investigated end-to-end on LetsDefend using SIEM log search, Cisco Talos threat intel, and a structured SOC playbook.

Result: True Positive — unsuccessful reflected XSS attempt, Internet → Company Network, no Tier 2 escalation required.



Incident Overview

Incident Summary

Field	Details
Event ID	116
Rule	SOC166 - Javascript Code Detected in Requested URL
Alert Type	Web Attack
MITRE ATT&CK	T1190 - Exploit Public-Facing Application
Source IP	112.85.42.13 (China Unicom Jiangsu Province Network)
Destination	172.16.17.17 (WebServer1002)
HTTP Method / Response	GET / 302 (0 bytes)
Device Action	Permitted
Attack Type	Cross-Site Scripting (XSS) — Reflected
Direction	Internet → Company Network
Planned Test	No
Attack Successful	No evidence of execution
Tier 2 Escalation	Not required

1. Alert Trigger

The alert fired on the following request to the /search/ endpoint:

```
https://172.16.17.17/search/?q=<$script>javascript:$alert(1)</script>
```

alert(1) is a standard XSS proof-of-concept string used to confirm whether injected JavaScript is being interpreted by the browser.

Before diving into the data, I followed a structured approach: understand why the rule fired, and identify the traffic direction, before drawing conclusions.

Understand Why the Alert Was Triggered

In order to perform a better analysis and to determine whether the triggered alert is false positive, it is first necessary to understand why the rule was triggered. Instead of starting the analysis directly, first understand why this rule was triggered.

- Examine the rule name. Rule names are usually created specifically for the attack to be detected. By examining the rule name, you can understand which attack you are facing.
- Detect between which two devices the traffic is occurring. It's a good starting point to understand the situation by learning about the direction of traffic, what protocol is used between devices, etc.

Next

Incident Details

Incident Name:	SOC166 - Javascript Code Detected in Requested URL
Description:	

Collect Data

Gather some information that can be gathered quickly to get a better understanding of the traffic. These can be summarized as follows.

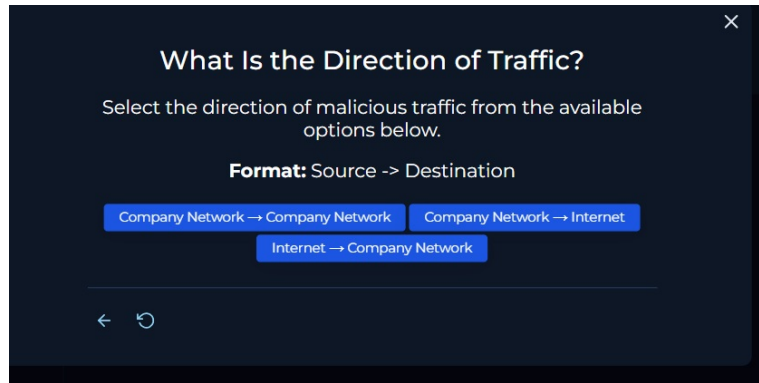
- Ownership of the IP addresses and devices.
- If the traffic is coming from outside (Internet);
 - Ownership of IP address (Static or Pool Address? Who owns it? Is it web hosting?)
 - Reputation of IP Address (Search in VirusTotal, AbuseIPDB, Cisco Talos)
- If the traffic is coming from company network;
 - Hostname of the device
 - Who owns the device (username)
 - Last user login time

Next

2. Traffic Direction Analysis

- **112.85.42.13** falls outside the RFC1918 private ranges (10.0.0.0/8, 172.16.0.0/12, 192.168.0.0/16) → public/external IP.
- **172.16.17.17** falls inside 172.16.0.0/12 → internal server (WebServer1002).

Direction: Internet → Company Network. This matters because the investigation and escalation criteria for internet-originated attacks differ from internal-to-internal traffic.



What Is the Direction of Traffic?

Select the direction of malicious traffic from the available options below.

Format: Source -> Destination

Company Network -> Company Network Company Network -> Internet

Internet -> Company Network

← ↻

Traffic direction determination

3. Payload & Classification

The payload was submitted directly through the q GET parameter and reflected back by the application rather than being stored or triggered client-side, which is consistent with **Reflected XSS**:

Attacker input → q parameter → inserted into response → browser interprets as JS



What Is The Attack Type?

Which of the following is the attack vector in the malicious traffic you have detected as a result of your investigations?

Command Injection IDOR LFI & RFI Other SQL Injection

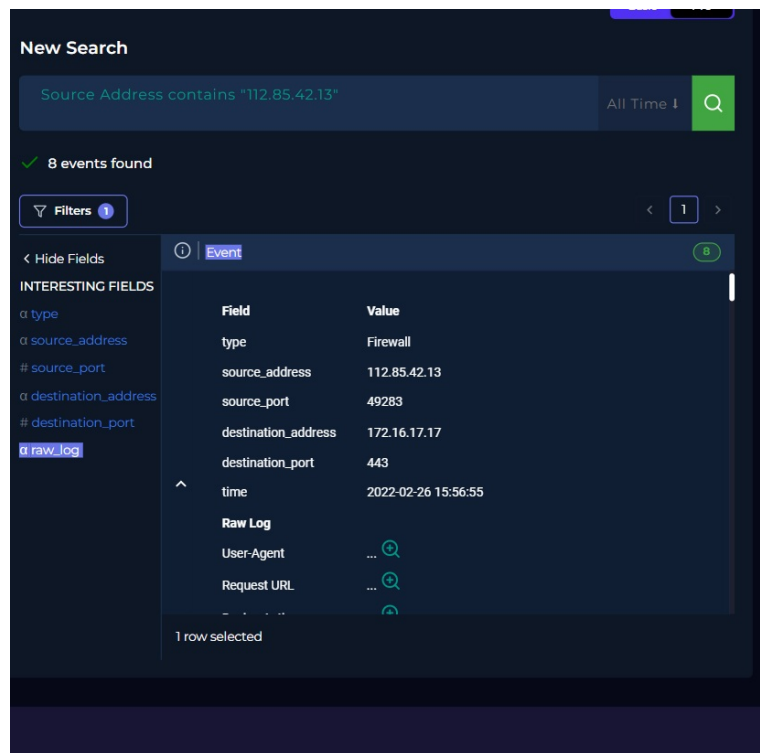
XML Injection XSS

← ↻

Classifying the attack type

4. SIEM Log Analysis

Pivoting on the source IP in the SIEM surfaced the raw firewall log for the request — source/destination address and port, timestamp, User-Agent, and the full request URL — used to confirm the request details independently of the alert summary.



SIEM search on source IP 112.85.42.13

The User-Agent (Firefox/40.1 on Windows NT 6.1) was noted as context only — User-Agent strings are trivially spoofable, so they weren't used as evidence of intent or success.

5. Threat Intelligence — Cisco Talos

Field	Result
Location	Lianyungang, China
Network Owner	China Unicom Jiangsu Province Network
Sender IP Reputation	Poor
Web Reputation	Neutral
Talos Block List	Not currently listed (expired)

LOCATION DATA

LIANYUNGANG, CHINA

OWNER DETAILS

IP ADDRESS

112.85.42.13

?

FWD/REV DNS MATCH

No data

HOSTNAME

-

?

DOMAIN

-

?

NETWORK OWNER

CHINA UNICOM JIANGSU PROVINCE NETWORK

CONTENT DETAILS

?

CONTENT CATEGORY

No established content categories

Think these category details are incorrect?

Submit Content Categorization Ticket

ADDITIONAL INFORMATION

IP ADDRESSES

WHOIS

EMAIL VOLUME DATA

LOCATION DATA

LIANYUNGANG, CHINA

OWNER DETAILS

IP ADDRESS

112.85.42.13

?

FWD/REV DNS MATCH

No data

HOSTNAME

-

?

DOMAIN

-

?

NETWORK OWNER

CHINA UNICOM JIANGSU PROVINCE NETWORK

CONTENT DETAILS

REPUTATION DETAILS

?

SENDER IP REPUTATION

Poor

Submit Sender IP Reputation Ticket

?

WEB REPUTATION

Neutral

Submit Web Reputation Ticket

EMAIL VOLUME DATA

LAST DAYLAST MONTH

?

EMAIL VOLUME

0.0

0.0

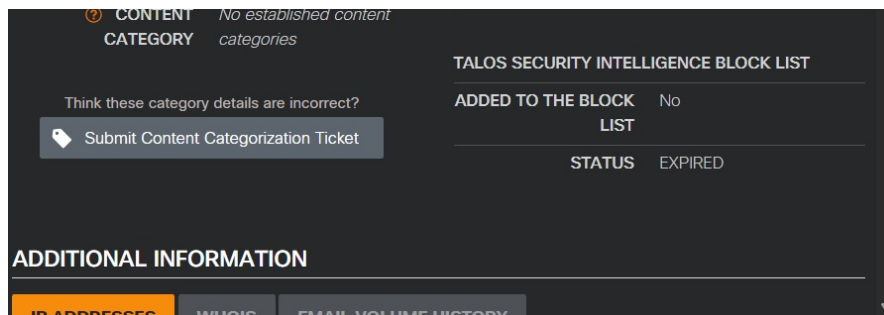
?

VOLUME CHANGE

0%

BLOCK LISTS

?

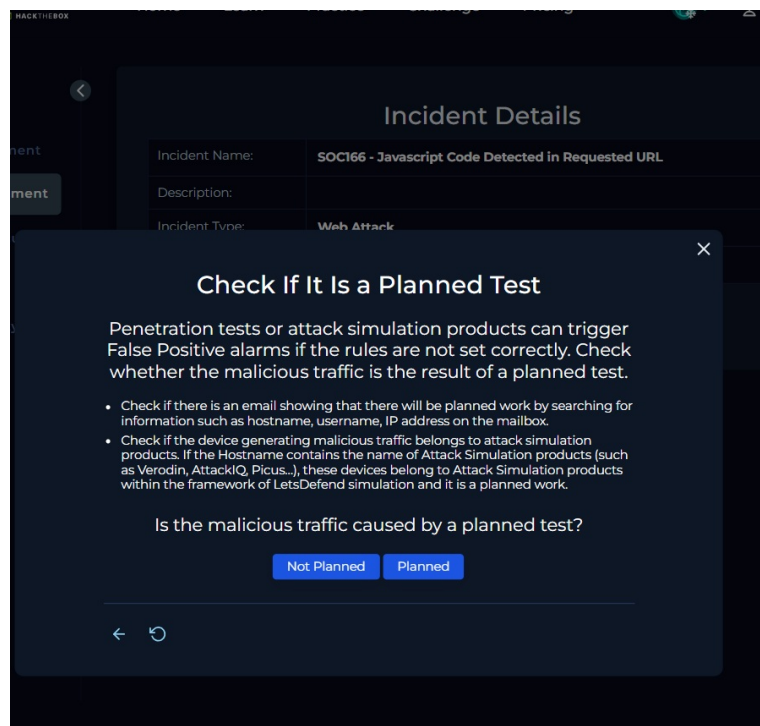


A “Poor” sender reputation is supporting context, not proof of malicious intent on its own — the Web Reputation was Neutral and the IP wasn’t actively block-listed. The strongest evidence here remained the payload itself.

6. Planned Test Check

Checked whether the traffic matched a known attack-simulation tool (Picus, AttackIQ, Verodin) or a scheduled pentest notification. The target hostname (WebServer1002) is the victim server, not a simulation device, and no supporting email/ticket was found.

Conclusion: Not a planned test.



Planned test verification

7. Was the Attack Successful?

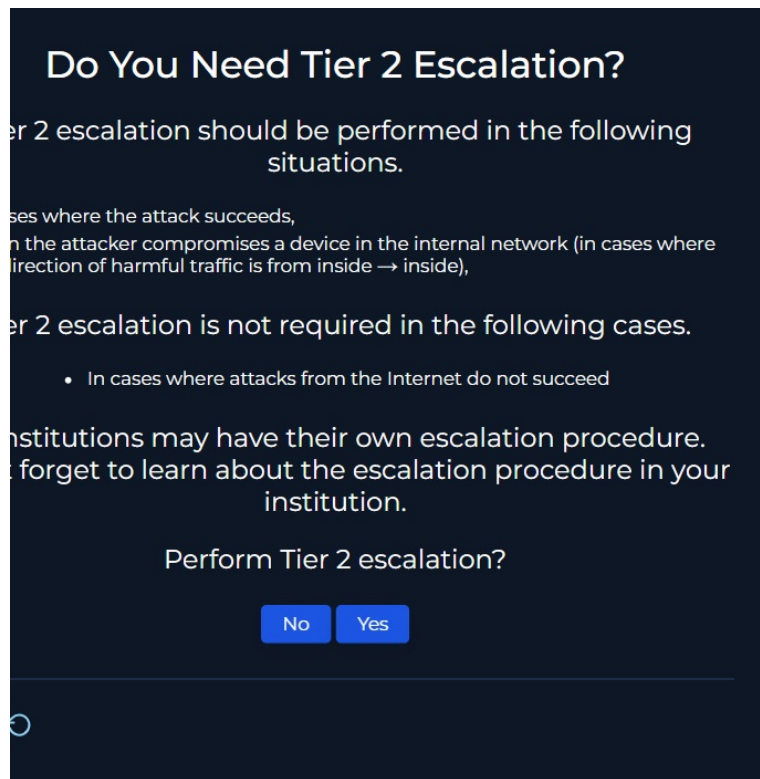
- Device Action: **Permitted** (not blocked — but permitted ≠ successful)
- Server response: **HTTP 302, 0-byte body**
- Follow-up request in the logs: /search/?q=test → **HTTP 200**, no payload present

No evidence the alert(1) payload was reflected into an executable context or actually ran in a browser.

Conclusion: Attack attempted, not demonstrated successful.

8. Tier 2 Escalation Decision

Escalation criteria: required if the attack **succeeds**, or if malicious traffic moves internal → internal. Neither applied here — the attack originated externally and did not succeed.

A screenshot of a dark-themed web form titled "Do You Need Tier 2 Escalation?". The form contains the following text: "Tier 2 escalation should be performed in the following situations." followed by a bulleted list: "• In cases where the attack succeeds, or when the attacker compromises a device in the internal network (in cases where the direction of harmful traffic is from inside → inside)". Below this, it says "Tier 2 escalation is not required in the following cases." followed by another bulleted list: "• In cases where attacks from the Internet do not succeed". Then, it states "Institutions may have their own escalation procedure. Do not forget to learn about the escalation procedure in your institution." At the bottom, there is a question "Perform Tier 2 escalation?" with two blue buttons labeled "No" and "Yes".

Do You Need Tier 2 Escalation?

Tier 2 escalation should be performed in the following situations.

- In cases where the attack succeeds, or when the attacker compromises a device in the internal network (in cases where the direction of harmful traffic is from inside → inside),

Tier 2 escalation is not required in the following cases.

- In cases where attacks from the Internet do not succeed

Institutions may have their own escalation procedure. Do not forget to learn about the escalation procedure in your institution.

Perform Tier 2 escalation?

No Yes

Tier 2 escalation decision

Conclusion: Tier 2 escalation not required.

Indicators of Compromise (IOCs)

Type	Value	Note
Source IP	112.85.42.13	External source of the XSS attempt
Destination IP	172.16.17.17	Internal web server (WebServer1002)
Malicious URL	https://172.16.17.17/search/?q=<\$script>javascript:\$alert(1)</script>	Reflected XSS payload

Final Verdict

Area	Result
Malicious traffic	Yes
Attack type	XSS (Reflected)
Direction	Internet → Company Network
Planned test	No
Successful exploitation	No evidence

Internal compromise	None identified
Tier 2 escalation	Not required
Classification	True Positive — unsuccessful XSS attempt

Skills Demonstrated

- SIEM log search and pivoting on IOCs
- Threat intelligence enrichment (Cisco Talos)
- Traffic direction / RFC1918 analysis
- XSS payload analysis and classification (Reflected vs Stored vs DOM-based)
- MITRE ATT&CK mapping (T1190)
- Structured SOC triage and escalation decision-making

Repository Structure

```
javascript-xss-log-analysis/  
├── README.md  
├── Investigation-Report.md      # full write-up  
├── screenshots/  
└── evidence/  
    └── sanitized-log.txt
```